

Table of Contents

Cisco Secure Workload — FedRAMP (Federal Risk and Authorization Management Program)

Reference Design | Moderate Baseline & Continuous Monitoring Evidence

Version: 1.0

Use Case: CSP or agency customer systems pursuing FedRAMP Authorization (P-ATO / ATO) with workload-tier controls

Baseline focus: FedRAMP Moderate (most common for SaaS and IaaS at Moderate impact)

Reader's Guide

Who this is for. System owners, ISSOs, CSP security architects, and Third-Party Assessment Organization (3PAO) support teams documenting **technical evidence** for NIST SP 800-53 Rev 5 controls in the **FedRAMP** context—especially information flow, boundary protection, vulnerability management inputs, configuration management, and continuous monitoring (ConMon).

Questions this reference design helps you answer:

- *How does CSW help satisfy **FedRAMP-scoped** parameters for **AC-4** (information flow enforcement) and **SC-7** (boundary protection) at the **workload** layer?*
- *What artifacts support **CA-7** continuous monitoring and annual assessment cycles without reducing everything to manual screenshots?*
- *How do **CM-2** / **CM-3** / **CM-8** narratives gain inventory and change-detection backing from CSW (ADM, drift, software inventory)?*
- *How can **RA-5** evidence incorporate **CVE awareness**, **EPSS**, and **attack-path** / **reachability** context from CSW?*
- *What can I put in a **POA&M** or closure package as automated evidence from CSW versus what still needs policy/procedure text?*

What you'll need. FIPS 199 categorization, draft **System Security Plan (SSP)** excerpts for in-scope controls, FedRAMP **Moderate** baseline control list, your **ConMon** strategy, integration plan for **SIEM** and ticketing, and **3PAO** evidence-format expectations.

Where to start. Sections 1–2 for FedRAMP overlay context; 3–8 for phased rollout; 9 for control mapping; 10–11 for boundaries, ConMon, POA&M, and 3PAO readiness.

Critical note: Cisco Secure Workload (CSW) as a product/service is not itself FedRAMP-authorized. This reference design describes how CSW deployed **on your system boundary** (customer responsibility) can produce **evidence** supporting **your** authorization package for **your** cloud system. CSPs must still map controls to inherited vs customer responsibility per the SSP.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply	Days 1–10

Phase	Goal	Key CSW actions	Typical duration
		compliance labels; create scope	
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Moderate baseline AC-4/SC-7/CA-7/SI-4 with ConMon-ready exports
- POA&M inputs from gap and drift reports
- 3PAO assessment preparation artefacts

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

FedRAMP authorizes cloud systems using **NIST SP 800-53 Rev 5** controls with **FedRAMP baselines and parameters**. This repo already includes [NIST 800-53 Rev 5 reference design coverage](#); this document adds **FedRAMP-specific** emphasis:

- **Moderate baseline** control expectations commonly evidenced in part by workload telemetry
- **Continuous monitoring (ConMon)** rhythm (monthly operational visibility, POA&M hygiene, annual assessments)
- **AC-4** and **SC-7** parameters that reference **enforcing approved information flows** and **boundary protection**—areas where CSW **microsegmentation** and **flow enforcement** directly contribute
- **POA&M** and **3PAO** evidence conventions (machine-readable exports, sampling methodology)

FedRAMP Moderate Themes → CSW Capabilities

FedRAMP theme	NIST families (examples)	CSW capabilities
Enforce information flows	AC-3, AC-4 , SC-7	Workload allowlists, default-deny segments, ADM-backed approvals
Continuous visibility	CA-7 , SI-4 , AU-*	Continuous flow + process telemetry; alert forwarding

FedRAMP theme	NIST families (examples)	CSW capabilities
Baseline & change	CM-2, CM-3 , CM-6, CM-8	ADM baseline; drift; software inventory reconciliation
Flaw / vuln management	RA-5 , SI-2	CVE visibility, scoring, EPSS , reachability- aware prioritization
IR support	IR-*	Forensic flow/process exports

2. Pre-Deployment Checklist

- ☐ **Authorization boundary** diagram updated (where CSW sensors/agents sit relative to major components)
- ☐ CSW cluster reachable from in-scope workloads (**egress 443** documented in SSP)
- ☐ **Customer vs CSP responsibility** table acknowledges CSW as customer-deployed tooling (if applicable)
- ☐ Identity for cloud connectors (AWS IAM, Azure SPN, GCP SA) follows **least privilege** (CM documentation)
- ☐ **SIEM** or **central log** destination approved for security event streaming (AU / SI-4 alignment)
- ☐ **Change management** process ready for sensor install and policy enforcement windows (**CM-2/CM-3**)
- ☐ **FedRAMP Moderate** control spreadsheet tagged with “CSW contributes (technical evidence)” rows

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 Linux Agent Install (Representative)

```
sudo rpm -ivh tet-sensor-<version>.rpm    # RHEL-family
# or
sudo dpkg -i tet-sensor-<version>.deb      # Debian-family
```

```
sudo systemctl enable --now csw-agent
systemctl status csw-agent
```

3.2 Windows

Deploy via signed MSI through your **CM-3**-controlled software channel; record the deployment in your change ticket.

3.3 Cloud

CSW UI → Platform → External Orchestrators

→ Connect AWS / Azure / GCP

→ Enable inventory + flow log ingestion per CSP documentation

3.4 FedRAMP Evidence — Deployment

Artifact	Purpose
Agent inventory export with versions	CM-8 component tracking
Connector IAM/SPN policy JSON	AC-6 / CM-6 least-privilege evidence
Network allowlist proof (443 to CSW)	SC-7 / architecture appendix

4. Phase 2 — Scope & Inventory Design (Days 6–12)

Align CSW **scopes** with **SSP segments** (e.g., web tier, app tier, data tier, management plane jump hosts).

4.1 Illustrative Scope Tree

FedRAMP-InScope	
├─ Management-Plane	# bastion, automation controllers
├─ Ingress-Edge instrumented)	# load balancers, API gateways (if
├─ App-Tier	
├─ Data-Tier	
├─ Security-Monitoring	# CSW, SIEM collectors (as applicable)
└─ DevTest-OutOfScope	# explicitly excluded per boundary

4.2 Labels for CM-8 and RM Reconciliation

Label	FedRAMP relevance
sdp-component-id	Map host to SSP attachment
data-impact	moderate / high (if multi-impact in same org)
patch-group	RA-5 remediation cadence
change-window	CM-3 correlation

Inventory reconciliation SOP:

1. Export CSW inventory (monthly)
 2. Compare to CMDB / CSP asset API
 3. Document deltas: new = change review; missing = decommission proof
 4. Attach summary to ConMon monthly package
-

5. Phase 3 — Visibility & Baseline (Days 13–28)

5.1 ADM for Approved Information Flows (AC-4 / SC-7)

CSW UI → Investigate → Application Dependency Mapping

→ Workspace: "FedRAMP-Baseline-<SystemAcronym>-<YYYYMM>"

→ Scope: FedRAMP-InScope (exclude DevTest-OutOfScope)

→ Duration: ≥ 30 days recommended for Moderate systems with monthly batch jobs

Document: “Approved flows” = ADM clusters **plus** signed architecture diagrams **plus** change tickets for exceptions.

5.2 Baseline Drift as Change Signal (CM-2 / CM-3)

CSW UI → Investigate → ADM

→ Compare current window to baseline workspace

→ New external destinations or cross-tier paths → open CM ticket if unexplained

6. Phase 4 — Policy Design (Weeks 5–7)

6.1 AC-4 / SC-7 — Information Flow & Boundary (FedRAMP Parameters)

FedRAMP parameters for **AC-4** and **SC-7** expect **documented enforcement** of authorized communications. CSW contributes **workload-level** enforcement **inside** the authorization boundary.

Example policy pattern (conceptual):

Default deny between tiers except ADM-approved paths

DENY: App-Tier → Data-Tier (default)

ALLOW: App-Tier → Data-Tier (tcp/5432 to approved DB pool scope only)

ALLOW: Management-Plane → App-Tier (tcp/22 from Jump-Host subnet only
– document in SSP)

Management ingress tightly constrained

DENY: Internet → Management-Plane

Log residual unmatched flows for SI-4 monitoring

LOG: unmatched flows → soc-queue

Translate into your **Defend** → **Segmentation** workspace; run **Simulation** until exceptions are chartered.

6.2 Simulation → Enforcement Gates (CA-2 / CA-7 Support)

Gate	Evidence
Simulation report	Shows blast-radius analysis before enforcement

Gate	Evidence
CAB approval	CM-3 change record
Enforcement cutover	Policy version export + timestamp

7. Phase 5 — Enforcement & Continuous Operations

7.1 CA-7 — Continuous Monitoring Hooks

FedRAMP ConMon expects **ongoing** insight into control effectiveness. Use CSW outputs on a **monthly** (minimum) cadence:

Activity	Control families bolstered
Export policy workspace version + diff	AC-3, AC-4, SC-7
Vulnerability report scoped to prod	RA-5, SI-2
Alert summary with MTTR	SI-4, IR-4
Inventory vs CMDB reconciliation	CM-8
ADM refresh / drift log	CM-2, CM-3

7.2 SI-4 — System Monitoring

Forward alerts with **5-tuple**, **process context**, **policy action**, and **workload identity** to your **SIEM** for daily SOC review (AU-6 alignment).

```
# Example pattern: verify SIEM HTTP Event Collector from build
pipeline
# curl -sk "$SPLUNK_HEC_URL/services/collector/health" -H
"Authorization: Splunk $HEC_TOKEN"
```

8. Phase 6 — RA-5 Vulnerability Management & Reachability

8.1 CSW Vulnerability & Prioritization Workflow

CSW UI → Investigate → Vulnerability Report

- Scope: FedRAMP-InScope production
- Sort: CVSS descending
- Layer: reachability / exposure context where available
- Export: CSV for POA&M bulk references

8.2 EPSS and Exploit Awareness

When your deployment exposes **EPSS** or threat-intel overlays, document how **RA-5** prioritization uses **exploit likelihood** plus **CSW reachability** (not CVSS alone).

8.3 POA&M-Ready Fields

For each open finding, capture: **CVE**, **asset ID**, **CSW scope**, **first seen**, **compensating control** (e.g., microsegment blocking exploit path), **planned patch date**.

9. Control Mapping: FedRAMP (Moderate) → CSW → Evidence

Control	Name (summary)	FedRAMP nuance	CSW capability	Evidence produced
AC-4	Information Flow Enforcement	Parameterized flow enforcement expectations	Microsegmentation; ADM-documented flows	Policy export; ADM diagrams; simulation reports
AC-3	Access Enforcement	Often paired with AC-4 narratives	Workload-level allow/deny	Enforcement logs
CA-7	Continuous Monitoring	ConMon deliverables to FedRAMP PMO / agency	Scheduled exports; dashboards	Monthly ConMon slide pack attachments
CM-2	Baseline Configuration	Baseline reviews	ADM baseline workspace	Baseline vs current comparison
CM-3	Configuration Change Control	Changes authorized	Drift alerts → tickets	Ticket IDs linked to CSW events
CM-8	System Component Inventory	Accurate inventory	CSW inventory export	Reconciliation spreadsheet
RA-5	Vulnerability Monitoring	Scanning + remediation tracking	CVE + CVSS + EPSS + reachability views	Vuln CSV; POA&M rows
SC-7	Boundary Protection	Parameterized boundary definitions	Segmentation between tiers / mgmt	Topology + policy mapping
SI-4	System Monitoring	Ongoing monitoring	Process + flow telemetry	SIEM ingest proof; sample alerts
AU-2/3/6/12	Audit events & review	Centralized logging	Rich flow/process	Field mapping doc;

Control	Name (summary)	FedRAMP nuance	CSW capability	Evidence produced
			audit records	retention S3/Splunk
IR-4	Incident Handling	Response evidence	Forensic export bundles	Incident attachment set

9.1 FedRAMP Parameters — AC-4 and SC-7 (Workload Tier)

FedRAMP control narratives and parameters expect you to **approve** information flows and **protect** boundaries. In practice, assessors look for:

1. **Written policy** defining authorized communication paths (who may talk to whom, on which ports and protocols).
2. **Technical enforcement** consistent with that policy—not only “we have a firewall at the edge.”
3. **Evidence of operation:** logs showing denies/alerts, change control when paths change, and periodic review.

How CSW fits: Use **ADM** to derive the **observed** application graph, reconcile it to the **approved** architecture in the SSP, then encode the delta in **segmentation workspaces**. For **SC-7**, position CSW as **internal segmentation** and **host-level boundary** enforcement **within** the FedRAMP authorization boundary (complements VPC/VNet edges, NGFWs, and cloud native controls). Always cite **inheritance** where the CSP’s FedRAMP authorization covers hypervisor or backbone controls.

9.2 CA-7 Continuous Monitoring — Operationalizing CSW

FedRAMP ConMon emphasizes **ongoing authorization**. Map CSW activities to your **ConOps** (not only annual assessment):

ConMon activity	Example CSW artifact
Vulnerability disposition	Weekly scoped vulnerability export; POA&M linkage
Significant change detection	ADM drift summary after major releases
Incident trend	Alert volume / MTTR with sample forensic exports
Inventory accuracy	CSW ↔ CMDB reconciliation signed by ISSO

10. Boundaries — What CSW Does **Not** Cover

- **FedRAMP authorization for CSW itself:** Using CSW does not inherit FedRAMP for the Cisco service; your SSP must state inheritance and responsibilities correctly.

- **Complete Moderate baseline:** Many controls are **policy, personnel, physical, or IAM-console** tasks outside CSW (e.g., full **AT**-* training records).
 - **Independent scanning tools:** RA-5 often still requires **authenticated scanner** exports; CSW **complements** with exposure context, not wholesale replacement of scanner SOPs.
 - **Encryption validation:** CSW can flag some **cleartext** protocols; **cryptographic module validation** references **FIPS 140** separately ([FIPS reference design](#) in this repo).
 - **CSP control inheritance:** Customer Dedicated vs FedRAMP High Lift varies; always reconcile with **FedRAMP Marketplace** authorization for your underlying cloud.
-

11. Audit Preparation, ConMon, POA&M, and 3PAO Evidence

11.1 Continuous Monitoring (ConMon) Content Pack

Prepare a **recurring** folder structure your ISSO can upload or email per FedRAMP guidance:

```
ConMon-YYYY-MM/
├── 00-cover-sheet.docx
├── csw-inventory-export-YYYY-MM-DD.csv
├── csw-policy-workspace-<name>-vNN-export.json|pdf
├── csw-vuln-report-YYYY-MM-DD.csv
├── csw-adm-drift-summary-YYYY-MM.pdf
├── siem-ingest-health-screenshot.png
└── poam-delta-summary.xlsx # new/closed rows referencing CSW IDs
```

11.2 POA&M Evidence from CSW

POA&M scenario	CSW evidence
Delayed patch on internet-facing tier	Vuln report row + compensating deny rule + expiration date
New unexpected listener	Process/listener report + CM ticket
Segmentation gap found in test	Simulation report + enforced policy version after fix

11.3 3PAO Assessment Preparation

- **Sampling plan:** Provide assessors **N** random alerts with **full flow + process** exports (not cropped images).
- **Tracing:** For each sampled control (e.g., AC-4), show **SSP narrative paragraph** → **CSW policy row** → **live log line** alignment.
- **Independence:** 3PAO validates; your team supplies **read-only** access or redacted exports per rules of engagement.

11.4 Bash / API Documentation Snippets for Engineers

```
# Document agent freshness for assessors (run from jump host with CLI
access if enabled)
# csw-agent-health.sh – pseudo-example; replace with your supported
health endpoint
```

```
curl -sS "https://<csw-api>/api/v1/agents?scope=FedRAMP-InScope" \
-H "Authorization: Bearer $CSW_API_TOKEN" \
| jq '.results[] | {hostname, version, last_seen}'
```

Archive monthly evidence

```
tar czf "csw-common-$(date +%Y-%m).tgz" ConMon-$(date +%Y-%m)/
```

11.5 Reporting & Evidence Collection (Assessment Cycle)

Evidence item	CSW source	Typical control hooks
Information-flow enforcement log	Defend → Policy Analysis / enforcement history	AC-4, SC-7
Flow audit trail (in-scope)	Investigate → Flow Search	AU-*, SI-4
Policy violation / deny events	Alerts	AC-3, SC-7, IR-4
Patch-priority report	Investigate → Vulnerability	RA-5, SI-2
Baseline vs current graph	Investigate → ADM	CM-2, CM-3
Workload inventory snapshot	Manage → Inventory export	CM-8

Schedule **monthly** inventory reconciliation and **quarterly** policy workspace review; align frequency to your **ConMon** plan and agency requirements.

12. Common Pitfalls

Pitfall	Mitigation
Claiming CSW satisfies AC-4/SC-7 without SSP linkage	Add explicit SSP subsections mapping components → CSW scopes → policy workspace IDs.
Screenshots-only evidence for 3PAO	Provide exports (CSV/JSON/PDF) with timestamps and scope metadata.
Treating CSW reachability as a replacement for RA-5 scanning	Keep authenticated scanner outputs; use CSW for prioritization and exposure context.
Skipping simulation on production	Run Simulation ; attach CAB tickets to enforcement changes (CM-3).
Out-of-date ADM after every major release	Re-baseline ADM per release; file drift summary with change record.
Confusing vendor FedRAMP with	Document CSW as customer

Pitfall	Mitigation
your system ATO	responsibility or dependency per FedRAMP Marketplace due diligence.

Appendix A — Alignment to In-Repo NIST 800-53 Reference design

For control family deep dives (AC, AU, CM, IR, RA, SC, SI), see:

[NIST SP 800-53 Rev 5 Reference Design](#)

Use this FedRAMP document for **ConMon**, **FedRAMP parameters**, **POA&M**, and **3PAO packaging** specifics.

Appendix B — Related Frameworks

- [NIST SP 800-207](#) — ZTA alignment for boundary narratives
- [CMMC 2.0](#) — defense industrial scenarios with similar evidence discipline
- [MITRE ATT&CK \(Enterprise\)](#) — offensive technique coverage mapping for SI-4/IR testing

Document prepared for customer FedRAMP authorization support. Replace system acronym, scope names, and bracketed placeholders before assessor or PMO delivery. CSW product FedRAMP status must be verified independently on the FedRAMP Marketplace and your vendor dependency list.